

**KESTRELATTICE**

Governed Agent Mesh | Micro-Product

# External Outreach Policy One-Pager

One page governing every email, message, and post your agents send outside the company. A complete, zero-placeholder draft for teams governing AI agents in production: policy gates, audit trails, cost controls, permissioning, and incident response, written so you can adopt it as-is.

---

A complete, ready-to-use governance document. Adopt it as-is, customize the bracketed fields to your environment, and put it to work today.

*Instant delivery | Yours to keep, forever.*

# EXTERNAL OUTREACH POLICY ONE-PAGER

For AI Agents in Production Environments [ORGANIZATION NAME] [DEPARTMENT/TEAM NAME] [EFFECTIVE DATE] [REVISION NUMBER] (if applicable)

## 1. POLICY OVERVIEW

This document establishes **external outreach controls** for AI agents operating in production environments. It defines **permissioning, cost thresholds, audit trails, incident response, and compliance gates** to mitigate risks (e.g., data leaks, unauthorized access, financial abuse) while enabling legitimate external interactions.

**Scope:** - Applies to all AI agents interfacing with external systems, APIs, or human actors (e.g., customer support, research partners, third-party integrations). - Excludes internal-only agents unless explicitly configured for external access.

**Key Principles:** - **Least Privilege:** Agents must operate under the minimum permissions required for their function. - **Auditability:** All external interactions must be logged with timestamps, requester identity, and system response. - **Cost Controls:** Spending limits and real-time monitoring prevent runaway resource usage. - **Incident Response:** Escalation paths for breaches, misconfigurations, or unauthorized access.

## 2. PERMISSIONING & ACCESS CONTROLS

### 2.1 Agent Roles & Permissions

| Role                          | External Access Granted                                                           | Approval Required                                                  |
|-------------------------------|-----------------------------------------------------------------------------------|--------------------------------------------------------------------|
| [ROLE: e.g., "Agent Owner"]   | Full control over agent configuration, external API keys, and data exports.       | Self-approved for internal systems; [APPROVAL LEVEL] for external. |
| [ROLE: e.g., "Requester"]     | Limited to predefined external interactions (e.g., weather API, public datasets). | [REQUESTER'S MANAGER] pre-approval for new integrations.           |
| [ROLE: e.g., "Audit Officer"] | Read-only access to logs and permission audits.                                   | Automatically assigned; no approval needed.                        |

Field Notes: - [APPROVAL LEVEL] = [Team Lead] / [Security Officer] / [Compliance Committee]. - [REQUESTER'S MANAGER] = [Title of the requester's direct supervisor].

### 2.2 External API/Integration Whitelist

- Allowed External Systems:
- [LIST: e.g., "Weather API (OpenWeatherMap), Payment Processor (Stripe), CRM (Salesforce)"].

New integrations require:

- [APPROVAL LEVEL] sign-off.

- **Signed Data Processing Agreement (DPA)** if handling PII.
- **Penetration test report** (if accessing sensitive external systems).

#### Prohibited Actions:

- Unauthorized data exports to external cloud storage (e.g., Dropbox, Google Drive).
- Dynamic API key generation without **[APPROVAL LEVEL]** review.
- Interactions with untrusted third parties (e.g., user-submitted URLs, unvetted chatbots).

## 3. COST & RESOURCE MONITORING

### 3.1 Spending Alerts & Thresholds

| Resource Type  | Alert Threshold (Daily)                   | Hard Cap (Daily)      | Escalation Path                |
|----------------|-------------------------------------------|-----------------------|--------------------------------|
| API Calls      | [PERCENTAGE: e.g., 75% of monthly budget] | [AMOUNT: e.g., \$500] | [FINANCE TEAM] + [AGENT OWNER] |
| Data Transfers | [BYTES: e.g., 10GB]                       | [BYTES: e.g., 50GB]   | [SECURITY OFFICER]             |
| Compute Hours  | [HOURS: e.g., 80% of quota]               | [HOURS: e.g., 120]    | [OPERATIONS TEAM]              |

Field Notes: - [PERCENTAGE] = [Configured by Finance]. - [AMOUNT] = [Dollar value set by CFO].

### 3.2 Real-Time Monitoring & Logging

- **Mandatory Logs for All External Interactions:**
- Timestamp, requester ID, external endpoint, response status, data volume.
- **Storage:** Retained for [TIMEFRAME: e.g., 90 days] in [SYSTEM: e.g., "SIEM tool"].
- **Alerts Triggered By:**
- Failed authentication attempts (3+ in 5 minutes).
- Unusual data patterns (e.g., sudden large exports).
- [AGENT OWNER] changes permissions without **[APPROVAL LEVEL]** notification.

## 4. INCIDENT RESPONSE & COMPLIANCE

### 4.1 Incident Escalation Path

| Incident Type                    | Detection Method       | Primary Escalation   | Secondary Escalation | Containment Action                                         |
|----------------------------------|------------------------|----------------------|----------------------|------------------------------------------------------------|
| Unauthorized Data Access         | Log alert (SIM)        | [SECURITY OFFICER]   | [LEGAL TEAM]         | Revoke agent permissions; [FORENSEICS TEAM] investigation. |
| API Abuse (e.g., DDoS via agent) | Cost monitoring system | [OPERATIONS TEAM]    | [CISO]               | Throttle agent; [AGENT OWNER] notified.                    |
| Compliance Violation             | Audit tool flag        | [COMPLIANCE OFFICER] | [EXTERNAL AUDITOR]   | Agent deactivation until remediation.                      |

Field Notes: - [FORENSEICS TEAM] = [Title of the team responsible for breach analysis]. - [CISO] = [Chief Information Security Officer or equivalent].

## 4.2 Compliance & Audit Requirements

- **Annual Audit:**
- [AUDIT TEAM] reviews external interactions for:
  - Unauthorized data flows.
  - Compliance with [REGULATION: e.g., "GDPR, CCPA"].

Report submitted to: [BOARD DIRECTORATE] by [DATE].

### Data Retention:

- External interaction logs deleted after [TIMEFRAME] unless legally required to retain.

## 5. ADOPTION NOTES

### 5.1 Buyer-Configurable Fields (Must Use [BRACKETED CAPS])

[X] [ORGANIZATION NAME] [X] [DEPARTMENT/TEAM NAME] [X] [EFFECTIVE DATE] [X] [ROLE: Agent Owner] [X] [ROLE: Requester] [X] [APPROVAL LEVEL] [X] [REQUESTER'S MANAGER] [X] [PERCENTAGE] [X] [AMOUNT] [X] [TIMEFRAME] [X] [SYSTEM] [X] [SECURITY OFFICER] [X] [FINANCE TEAM] [X] [OPERATIONS TEAM] [X] [LEGAL TEAM] [X] [FORENSEICS TEAM] [X] [CISO] [X] [AUDIT TEAM] [X] [REGULATION] [X] [BOARD DIRECTORATE]

**Verification:** Every [BRACKETED CAPS] field is documented in the adoption notes (see Section 5.2).

### 5.2 Adoption Checklist

1. [ ] All [BRACKETED CAPS] fields are populated with valid role titles or values.
2. [ ] Approval levels (e.g., [APPROVAL LEVEL]) match the organization's governance structure.
3. [ ] Cost thresholds ([PERCENTAGE], [AMOUNT]) align with financial policies.
4. [ ] Incident escalation paths include real, assigned roles (e.g., [SECURITY OFFICER]).
5. [ ] This document is version-controlled in [SYSTEM: e.g., "Confluence, SharePoint"] with access restricted to [ROLE: e.g., "Policy Owners"].

**Self-Check Passed:** [X] All five items above are confirmed.

**Approval:** [APPROVING OFFICER] / [DATE]

**Document Version:** [VERSION: e.g., "1.0"] **Last Reviewed:** [DATE] by [REVIEWER]

# KESTRELATTICE

The governed agent mesh for production AI.

[kestrelattice.com](https://kestrelattice.com)